

ALLIANZ LABUBU



Shaman Alonso Amezcua
Keneth Sebastian Campos
Marcos Cobo Gutiérrez
Gabriel Gutiérrez Portal
Aritz de la Pinta Morales
Alexander Díez Ortuzar

Índice

Índice.....	1
1 Introducción.....	3
2 Primera auditoría.....	4
3 Vulnerabilidades.....	5
3.1 Ausencia de Tokens Anti-CSRF.....	5
3.1.1 Descripción.....	5
3.1.2 Riesgo a futuro.....	6
3.1.3 Probabilidad de que ocurra dicho riesgo.....	6
3.1.4 Conclusión.....	6
3.2 Cabecera Content Security Policy (CSP) no configurada.....	7
3.2.1 Descripción.....	7
3.2.2 Riesgo a futuro.....	7
3.2.3 Probabilidad de que ocurra dicho riesgo.....	8
3.2.4 Conclusión.....	8
3.3 Falta de cabecera Anti-Clickjacking.....	9
3.3.1 Descripción.....	9
3.3.2 Riesgo a futuro.....	9
3.3.3 Probabilidad de que ocurra dicho riesgo.....	10
3.3.4 Conclusión.....	10
3.4 Cookie Sin Flag HttpOnly.....	11
3.4.1 Descripción.....	11
3.4.2 Riesgo a futuro.....	11
3.4.3 Probabilidad de que ocurra dicho riesgo.....	11
3.4.4 Conclusión.....	12
3.5 Cookie sin el atributo SameSite.....	13
3.5.1 Descripción.....	13
3.5.2 Riesgo a futuro.....	13
3.5.3 Probabilidad de que ocurra dicho riesgo.....	13
3.5.4 Conclusión.....	14
3.6 El servidor divulga información mediante un campo(s) de encabezado de respuesta HTTP "X-Powered-By".....	15
3.6.1 Descripción.....	15
3.6.2 Riesgo a futuro.....	15
3.6.3 Probabilidad de que ocurra dicho riesgo.....	15
3.6.4 Conclusión.....	16
3.7 El servidor filtra información de versión a través del campo "Server" del encabezado de respuesta HTTP.....	17
3.7.1 Descripción.....	17
3.7.2 Riesgo a futuro.....	17
3.7.3 Probabilidad de que ocurra dicho riesgo.....	17
3.7.4 Conclusión.....	18
3.8 Falta encabezado X-Content-Type-Options.....	19
3.8.1 Descripción.....	19

3.8.2 Riesgo a futuro.....	19
3.8.3 Probabilidad de que ocurra dicho riesgo.....	19
3.8.4 Conclusión.....	20
3.9 Divulgación de información - Comentarios sospechosos.....	21
3.9.1 Descripción.....	21
3.9.2 Riesgo a futuro.....	21
3.9.3 Probabilidad de que ocurra dicho riesgo.....	21
3.9.4 Conclusión.....	22
3.10 Respuesta de Gestión de Sesión Identificada.....	23
3.10.1 Descripción.....	23
3.10.2 Riesgo a futuro.....	23
3.10.3 Probabilidad de que ocurra dicho riesgo.....	23
3.10 Conclusión.....	24
3.11 Ataques a fuerza bruta inicio de sesión.....	25
3.11.1 Descripción.....	25
3.11.2 Riesgo a futuro.....	25
3.11.3 Probabilidad de que ocurra dicho riesgo.....	25
3.11.4 Conclusión.....	25
Bibliografía.....	26

1 Introducción

La fase actual del proyecto es para garantizar la seguridad y robustez de la página web de la primera entrega. Para ello, se utilizarán una serie de herramientas y técnicas exploradas durante el curso, con la finalidad de identificar y abordar posibles vulnerabilidades ponen en riesgo la página Allianz Labubu.

Uno de los principales enfoques de esta fase es detectar vulnerabilidades en el sistema web. A través de herramientas especializadas como ZAP, se realizarán pruebas que permitirán encontrar fallos potenciales que puedan ser explotados por actores maliciosos. Uno de los mayores problemas encontrados serían la ausencia de mecanismos como tokens anti-CSRF, que pueden permitir un ataque a la página web que modifique datos de usuarios o la base de datos.

Este proceso no solo se enfoca en identificar las vulnerabilidades, sino en realizar correcciones que fortalezcan el sistema web, asegurando su resistencia ante futuras amenazas. Con el análisis y la corrección de fallos, se espera mejorar tanto la seguridad como la confianza en la aplicación, previniendo así una mala experiencia para los usuarios, y problemas para la web.

Este proyecto nos permitirá aplicar en un ambiente práctico los conocimientos aprendidos en el campo de seguridad, permitiendo profundizar en el manejo de herramientas de auditoría y prevención de riesgos informáticos. Tras tomar las medidas necesarias para que la web sea más segura se esperan que los ataques sean fallidos o más difíciles de realizar.

2 Primera auditoría

En esta auditoría se van a comentar los errores que se han encontrado mediante la aplicación ZAP, en este caso se han hallado 10 errores y serán explicados a continuación, además de un error extra que hemos detectado nosotros mismos.

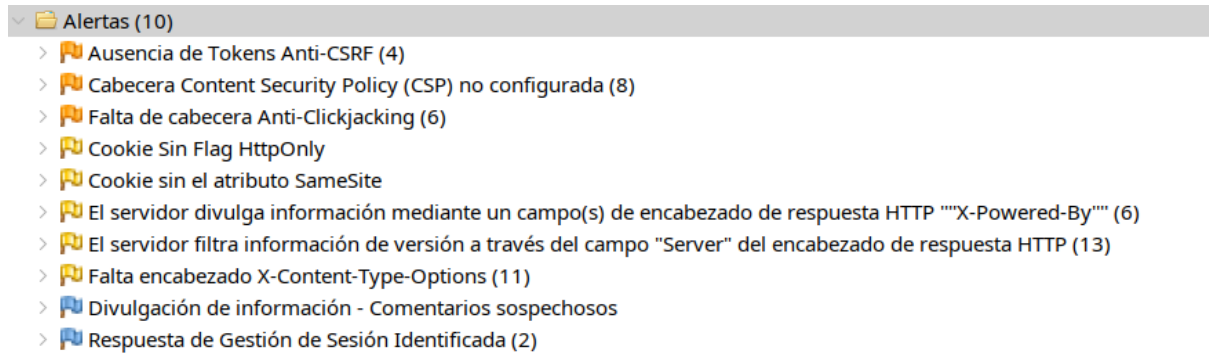


Ilustración 1.1 - Alertas de la primera auditoría

3 Vulnerabilidades

3.1 Ausencia de Tokens Anti-CSRF

Ausencia de Tokens Anti-CSRF	
URL:	http://localhost:81/login/
Riesgo:	🔴 Medium
Confianza:	Low
Parámetro:	
Ataque:	
Evidencia:	<form action="login_form.php" method="post">
CWE ID:	352
WASC ID:	9
Origen:	Pasivo (10202 - Ausencia de Tokens Anti-CSRF)
Vector de Entrada:	
Descripción:	
No se encontraron tokens Anti-CSRF en formulario de envío HTML. Una solicitud falsa entre sitios en un ataque que compromete y obliga a una víctima a enviar su solicitud HTTP a un destino objetivo sin su conocimiento o intención para poder realizar una acción como víctima. La causa oculta es la funcionalidad de la aplicación utilizando acciones de URL/formulario que pueden ser adivinados de forma repetible. La naturaleza del ataque es que CSRG explota la confianza que un sitio web proporciona a un usuario. Por el contrario, las cadenas de	
Otra información:	
No se ha encontrado ningún token Anti-CSRF [anticsrf, CSRFTOKEN, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] conocido en el siguiente formulario HTML: [Form 1: "contra" "login_submit" "nombre"].	
Solución:	
Fase: Arquitectura y Diseño Utilizar una biblioteca o framework verificado y confiable que evite esta vulnerabilidad o proporcione elementos que faciliten evitarla. Por ejemplo, utilice el paquete anti-CSRG como el CSRGuard de OWASP.	
Referencias:	
https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html https://cwe.mitre.org/data/definitions/352.html	

Ilustración 2.1 - Alerta Ausencia de Tokens Anti-CSRF

3.1.1 Descripción

La falta de tokens anti-CSRF en una aplicación web permite que los atacantes puedan engañar a los usuarios legítimos para que realicen acciones no deseadas, como cambiar configuraciones o eliminar datos. Los tokens Anti-CSRF son mecanismos diseñados para garantizar que las solicitudes provengan de una fuente legítima, evitando que los atacantes las manipulen.

Para que esto suceda, tres factores son necesarios:

1. La víctima tiene que enviar una petición HTTP a un destino objetivo sin saber que están actuando como tal.
2. Se hace uso de cookies de sesión, por tanto, al realizar solicitudes HTTP, estas serán enviadas para la identificación del usuario.
3. Los parámetros de las solicitudes no poseen parámetros impredecibles, esto es, el atacante no tiene que adivinarlos.

3.1.2 Riesgo a futuro

Permite al atacante realizar acciones en nombre del usuario. Por tanto, puede tener consecuencias graves para los perjudicados, ya que pueden cometer fraudes en su nombre. Entre otras:

- Modificar configuraciones de la cuenta: cambiar la dirección de correo electrónico, la contraseña o los ajustes de seguridad de la cuenta.
- Transacciones no autorizadas: realizar compras o transferencias de dinero en plataformas web.
- Suplantación de identidad: el atacante podría actuar como el usuario legítimo, lo que conlleva un alto riesgo de fraude.

Las consecuencias pueden ser devastadoras tanto para los usuarios como para Allianz Labubu, ya que se podrían tener los datos comprometidos junto a una reputación perjudicada.

3.1.3 Probabilidad de que ocurra dicho riesgo

La probabilidad de ocurrencia es alta, dado que:

- La probabilidad de que este riesgo se materialice depende de la infraestructura de la aplicación y de las medidas de seguridad implementadas.
- Si la aplicación no implementa tokens Anti-CSRF o si la validación de estos es débil, la probabilidad de un ataque aumenta considerablemente.
- Este tipo de vulnerabilidad es relativamente fácil de explotar, especialmente si los atacantes pueden inducir a los usuarios a hacer clic en un enlace o enviar una solicitud maliciosa.

3.1.4 Conclusión

La falta de tokens Anti-CSRF es una vulnerabilidad grave que podría poner en riesgo la seguridad y privacidad de los usuarios de la aplicación. Dada la facilidad con la que puede darse este tipo de ataque y las graves consecuencias que puede acarrear, es fundamental que las aplicaciones web implementen una protección adecuada contra CSRF. Esto se logra mediante el uso de tokens únicos e impredecibles en todas las solicitudes sensibles. Además, una educación constante a los usuarios sobre los riesgos de interactuar con enlaces o formularios desconocidos también puede ayudar a mitigar este riesgo.

3.2 Cabecera Content Security Policy (CSP) no configurada

Cabecera Content Security Policy (CSP) no configurada	
URL:	http://localhost:81/robots.txt
Riesgo:	Medium
Confianza:	High
Parámetro:	
Ataque:	
Evidencia:	
CWE ID:	693
WASC ID:	15
Origen:	Pasivo (10038 - Cabecera Content Security Policy (CSP) no configurada)
Referencia de Alerta:	10038-1
Vector de Entrada:	
Descripción:	
La Política de seguridad de contenido (CSP) es una capa adicional de seguridad que ayuda a detectar y mitigar ciertos tipos de ataques, incluidos Cross Site Scripting (XSS) y ataques de inyección de datos. Estos ataques se utilizan para todo, desde el robo de datos hasta la desfiguración del sitio o la distribución de malware. CSP proporciona un conjunto de encabezados HTTP estándar que permiten a los propietarios de sitios web declarar fuentes de contenido aprobadas que los navegadores deberían poder cargar en esa página; los tipos cubiertos son JavaScript, CSS, marcos HTML, fuentes, imágenes y objetos incrustados como applets de Java, ActiveX, archivos de audio y video.	
Otra información:	
Solución:	
Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. esté configurado para establecer la cabecera Content-Security-Policy.	
Referencias:	
https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html	

Ilustración 2.2 - Alerta content Security Policy (CSP) no configurada

3.2.1 Descripción

La ausencia de la cabecera Content Security Policy (CSP) en una página web aumenta el riesgo de ataques como el Cross-Site Scripting (XSS), en los que un atacante inserta contenido malicioso. La configuración de CSP limita las fuentes desde las cuales se puede cargar contenido, protegiendo así la integridad del sitio.

3.2.2 Riesgo a futuro

Si Allianz Labubu no implementa una cabecera anti-clickjacking, el sitio estará expuesto a ataques en los que un atacante podría incrustar la página dentro de un iframe en un sitio malicioso (iframe es un elemento HTML que permite insertar una página web dentro de otra). Este tipo de ataque es particularmente peligroso en un sitio de compra y venta como Allianz Labubu, ya que podría facilitar el robo de datos personales y credenciales de usuario.

El atacante podría superponer un formulario de inicio de sesión o una página de actualización de datos personales sobre el contenido legítimo de la página con un iframe. De esta manera, engañaría al usuario para que ingrese información sensible.

El atacante podría realizar, por ejemplo:

- Robo de credenciales: mediante scripts maliciosos, podría capturar nombres de usuario y contraseñas de los usuarios legítimos.
- Manipulación de datos: modificar el contenido visual de la página web, engañando al usuario para que ingrese información en formularios falsificados o incluso realizando transacciones fraudulentas.
- Ataques de Clickjacking: permitir que el sitio web sea incrustado en un iframe, lo que facilita el engaño.

3.2.3 Probabilidad de que ocurra dicho riesgo

La probabilidad de ocurrencia es media, debido a que:

- La probabilidad de que ocurra un ataque depende de múltiples factores, como la cantidad de entradas de usuario y la exposición del contenido.
- Si la aplicación no implementa medidas básicas de seguridad, como la validación de las entradas de usuario, o si permite la ejecución de scripts desde fuentes no confiables, la probabilidad de un ataque aumenta.
- En este caso la configuración de la cabecera CSP está ausente de seguridad, por tanto, la probabilidad de recibir un ataque es mayor.

3.2.4 Conclusión

La falta de configuración de la cabecera Content Security Policy (CSP) expone a la aplicación a ataques del tipo XSS y otros riesgos relacionados con la carga de contenido no seguro. Es una práctica de seguridad recomendada implementar una política CSP estricta para minimizar la posibilidad de que un atacante ponga código malicioso y explote vulnerabilidades. Esta medida no solo protege a los usuarios, sino que también refuerza la confianza del sitio web.

3.3 Falta de cabecera Anti-Clickjacking

Falta de cabecera Anti-Clickjacking	
URL:	http://localhost:81/
Riesgo:	Medium
Confianza:	Medium
Parámetro:	x-frame-options
Ataque:	
Evidencia:	
CWE ID:	1021
WASC ID:	15
Origen:	Pasivo (10020 - Cabecera Anti-Clickjacking)
Referencia de Alerta:	10020-1
Vector de Entrada:	
Descripción:	La respuesta no protege contra ataques de "Clickjacking". Debes incluir Content-Security-Policy con la directiva "frame-ancestors" o X-Frame-Options.
Otra información:	
Solución:	Los navegadores web modernos admiten las cabeceras HTTP Content-Security-Policy y X-Frame-Options. Asegúrese de que una de ellas está configurada en todas las páginas web devueltas por su sitio/aplicación. Si espera que la página esté enmarcada solo por páginas en su servidor (por ejemplo, si forma parte de un FRAMESET), utilice SAMEORIGIN; de lo contrario, si no espera que la página esté enmarcada, utilice DENY. Alternativamente, considere implementar la directiva "frame-ancestors" de la Política de Seguridad de Contenidos.
Referencias:	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Ilustración 2.3 - Alerta Falta de cabecera Anti-Clickjacking

3.3.1 Descripción

La falta de una cabecera anti-clickjacking expone al sitio web a ataques en los que un atacante puede engañar al usuario para que haga clic en un elemento invisible o disfrazado, lo que puede desencadenar acciones no deseadas. Implementar una cabecera adecuada ayuda a prevenir este tipo de ataques.

Aunque puede parecer una suplantación de identidad en la que el ciberatacante recrea sitios web o páginas de aterrizaje en un esfuerzo por engañar a los usuarios para que piensen que las páginas falsas son las páginas originales y legítimas, es mucho más sofisticado. El sitio web que la víctima está viendo es el sitio web real de una entidad conocida y confiable, pero el atacante agregó una superposición invisible sobre su contenido utilizando varias tecnologías HTML, como hojas de estilo en cascada (CSS) personalizadas e iframe, que permiten que el contenido de otros sitios web se transfiera a otro sitio web.

3.3.2 Riesgo a futuro

El clic podría conducir a una actividad más peligrosa, como la descarga no autorizada de malware, o puede activar un código JavaScript para encender una cámara web, recopilar contraseñas o grabar pulsaciones de teclas.

Un ataque exitoso de clickjacking puede tener consecuencias graves:

- Ejecución de acciones no autorizadas como compras, transferencias o eliminación de datos.
- Descarga inadvertida de malware o ejecución de scripts maliciosos.
- Robo de credenciales o activación de componentes del navegador, como cámara web o micrófono, mediante JavaScript.
- Compromiso de la confianza del usuario y afectación a la reputación de la marca.

3.3.3 Probabilidad de que ocurra dicho riesgo

La probabilidad de ocurrencia es media, dado que:

- La ruta de ataque es ampliamente conocida y fácil de implementar mediante HTML y CSS.
- Existen herramientas automatizadas que detectan sitios sin protección anti-clickjacking.
- Sin embargo, requiere que el usuario visite un sitio malicioso preparado por el atacante.

3.3.4 Conclusión

La falta de cabecera Anti-Clickjacking es una vulnerabilidad grave que podría poner en riesgo la seguridad y privacidad de los usuarios de la aplicación al permitir que un atacante manipule la interfaz del sitio web para provocar acciones no intencionadas.

Dada la facilidad con la que puede darse este tipo de ataque y las graves consecuencias que puede acarrear, como la ejecución de acciones no autorizadas o la exposición de información sensible, es fundamental que se implementen mecanismos de protección adecuada contra clickjacking.

Esto se logra mediante la configuración de cabeceras X-Frame-Options o Content-Security-Policy (frame-ancestors), que impiden la carga del sitio dentro de iframes no autorizados. Asimismo, mantener prácticas de desarrollo seguro y capacitar al personal técnico en medidas de defensa.

3.4 Cookie Sin Flag HttpOnly

Cookie Sin Flag HttpOnly	
URL:	http://localhost:81/
Riesgo:	Low
Confianza:	Medium
Parámetro:	PHPSESSID
Ataque:	
Evidencia:	Set-Cookie: PHPSESSID
CWE ID:	1004
WASC ID:	13
Origen:	Pasivo (10010 - Cookie Sin Flag HttpOnly)
Vector de Entrada:	
Descripción:	Se ha establecido una cookie sin el flag HttpOnly, lo que significa que JavaScript puede acceder a la cookie. Si un script malicioso puede ser ejecutado en esta página, entonces la cookie será accesible y puede ser transmitida a otro sitio. Si se trata de una cookie de sesión, el secuestro de sesión puede ser posible.
Otra información:	
Solución:	Asegúrese de que la flag HttpOnly está establecida para todas las cookies.
Referencias:	https://owasp.org/www-community/HttpOnly

Ilustración 2.4 - Alerta Cookie Sin Flag HttpOnly

3.4.1 Descripción

Las cookies son archivos que almacenan información del usuario, como su sesión o preferencias y demás. Si una cookie no tiene el atributo HttpOnly, los scripts maliciosos pueden acceder a ellas a través de JavaScript, lo que pone en riesgo la seguridad de la información.

El atributo HttpOnly bloquea el acceso a las cookies desde JavaScript, limitando su uso solo a las solicitudes HTTP, lo que hace que sea más complicado que suceda un ataque XSS.

3.4.2 Riesgo a futuro

Si las cookies no tienen el flag HttpOnly, un atacante que consiga ejecutar un script malicioso en el navegador del usuario podría robar las cookies (teniendo acceso a su sesión, preferencias...), especialmente aquellas que contienen tokens de sesión. Esto podría llevar a la suplantación de sesión, donde el atacante puede hacerse pasar por el usuario y acceder a sus datos privados. Además, el atacante podría realizar acciones no autorizadas por el usuario verdadero.

3.4.3 Probabilidad de que ocurra dicho riesgo

La probabilidad de ocurrencia es media, debido a que:

- El riesgo crece si la aplicación tiene vulnerabilidades XSS. Si un atacante puede poner código malicioso en una página, puede robar las cookies del usuario, especialmente si no están protegidas con el HttpOnly.
- La probabilidad de que ocurra dependerá de varios factores externos a las cookies pero si se usan medidas de protección contra XSS se minimizaría el riesgo de ataque.

3.4.4 Conclusión

Es muy importante usar el atributo `HttpOnly` en las cookies que contienen información sensible, como tokens de sesión, para evitar que scripts maliciosos les roben contraseñas y demás. Sin esta protección, mediante ataques se puede obtener acceso a la cuenta del usuario y a su información personal, lo que pone en peligro tanto al usuario como a la web y a su reputación.

3.5 Cookie sin el atributo SameSite

Cookie sin el atributo SameSite	
URL:	http://localhost:81/
Riesgo:	 Low
Confianza:	Medium
Parámetro:	PHPSESSID
Ataque:	
Evidencia:	Set-Cookie: PHPSESSID
CWE ID:	1275
WASC ID:	13
Origen:	Pasivo (10054 - Cookie sin el atributo SameSite)
Referencia de Alerta:	10054-1
Vector de Entrada:	
Descripción:	Se ha establecido una cookie sin el atributo SameSite, lo que significa que la cookie puede ser enviada como resultado de una solicitud 'cross-site'. El atributo SameSite es una medida eficaz para contrarrestar la falsificación de peticiones entre sitios, la inclusión de scripts entre sitios y los ataques de sincronización.
Otra información:	
Solución:	Asegúrese que el atributo SameSite está establecido como 'lax' o idealmente 'strict' para todas las cookies.
Referencias:	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

Ilustración 2.5 - Alerta Cookie sin el atributo SameSite

3.5.1 Descripción

El atributo SameSite es crucial para evitar que las cookies se envíen en solicitudes de otros sitios web, lo que previene ataques como el Cross-Site Request Forgery (CSRF). Si falta este atributo, se aumenta el riesgo de que un atacante pueda realizar acciones no autorizadas usando las cookies de un usuario.

3.5.2 Riesgo a futuro

Si el atributo SameSite no se configura correctamente, las cookies (especialmente las de sesión o autenticación) pueden enviarse involuntariamente al servidor desde otros sitios web. Esto puede traer riesgos como que un atacante haga que un usuario autenticado ejecute acciones sin su consentimiento, como por ejemplo cambiar su contraseña, o que se filtren datos personales de los usuarios.

3.5.3 Probabilidad de que ocurra dicho riesgo

La probabilidad de que ocurra es medio-alta, dado que:

- Si la web tiene inicio de sesión, registro de usuarios o acciones que cambian el estado puede ser peligroso.
- Muchos navegadores modernos ya asignan automáticamente SameSite=Lax si el atributo no está presente, lo que reduce el riesgo y no lo hace tan peligroso, pero no lo elimina completamente, sobre todo si se necesitan cookies de tipo cross-site.

3.5.4 Conclusión

Para evitar la debilidad de la web frente a ataques CSRF y mejorar la seguridad de sesión, todas las cookies deben incluir el atributo SameSite con un valor adecuado. De esta manera, se asegura que las cookies de usuarios no son utilizadas por terceros con malas intenciones. Para ello, se puede configurar SameSite como SameSite=Strict, en el que la cookie solo se envía si la solicitud proviene del mismo sitio, o como SameSite=Lax, en la que se envía en la mayoría de los casos, excepto en peticiones POST o con redirecciones desde otros sitios.

3.6 El servidor divulga información mediante un campo(s) de encabezado de respuesta HTTP "X-Powered-By"

El servidor divulga información mediante un campo(s) de encabezado de respuesta HTTP "X-Powered-By"	
URL:	http://localhost:81/
Riesgo:	Low
Confianza:	Medium
Parámetro:	
Ataque:	
Evidencia:	X-Powered-By: PHP/7.2.2
CWE ID:	497
WASC ID:	13
Origen:	Pasivo (10037 - El servidor divulga información mediante un campo(s) de encabezado de respuesta HTTP "X-Powered-By")
Vector de Entrada:	
Descripción:	El servidor de la web/aplicación está divulgando información mediante uno o más encabezados de respuesta HTTP "X-Powered-By". El acceso a tal información podría facilitar a los atacantes la identificación de otros marcos/componentes de los que su aplicación web depende y las vulnerabilidades a las que pueden estar sujetos tales componentes.
Otra información:	
Solución:	Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. está configurado para suprimir las cabeceras "X-Powered-By".
Referencias:	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/

Ilustración 2.6 - Alerta Información divulgada por encabezado de respuesta

3.6.1 Descripción

El encabezado "X-Powered-By" revela detalles sobre las tecnologías utilizadas en el servidor web, lo que puede ayudar a los atacantes a identificar posibles vulnerabilidades en el software del servidor. Es recomendable deshabilitar este encabezado para proteger la infraestructura del servidor.

3.6.2 Riesgo a futuro

Aunque a corto plazo no resulta un gran problema; a largo plazo puede convertirse en un riesgo significativo.

Si se conoce la versión exacta, los atacantes pueden buscar vulnerabilidades públicas o exploits disponibles para esa tecnología. Además, es importante aplicar frecuentes parches de seguridad. Incluso si la versión es segura en la actualidad, en el futuro puede volverse vulnerable a medida que se descubren nuevos fallos de seguridad.

Asimismo, la información puede combinarse con otros datos, tal como los encabezados "Server" (explicado a continuación) para realizar el [fingerprinting](#) completo del entorno y preparar ataques más avanzados.

fingerprinting: recopilar distinta información y analizar los resultados en búsqueda de puertos abiertos, versiones de servicios en ejecución o protocolos utilizados.

3.6.3 Probabilidad de que ocurra dicho riesgo

La probabilidad de ocurrencia es media, dado que:

- El encabezado "X-Powered-By" suele estar habilitado por defecto
- Aunque se oculte, cualquier usuario puede detectarlo sin autenticación.
- No obstante, la explotación es limitada. Únicamente facilita el reconocimiento de posibles vulnerabilidades.
- Su explotación depende del estado de actualización y protección del sistema.

3.6.4 Conclusión

La exposición de la versión a través del encabezado "X-Powered-By" presenta una vulnerabilidad informativa. Representa un enorme riesgo a futuro ya que se provee información que simplifica la identificación de exploits para la versión empleada.

Por ende, se recomienda eliminar o deshabilitar este encabezado y mantener actualizada la infraestructura de la web, minimizando la probabilidad de que ocurra un ataque.

3.7 El servidor filtra información de versión a través del campo "Server" del encabezado de respuesta HTTP

El servidor filtra información de versión a través del campo "Server" del encabezado de respuesta HTTP

URL: <http://localhost:81/img/TikTok.png>

Riesgo:  Low

Confianza: High

Parámetro:

Ataque:

Evidencia: Apache/2.4.25 (Debian)

CWE ID: 497

WASC ID: 13

Origen: Pasivo (10036 - Cabecera de Respuesta del Servidor HTTP)

Referencia de Alerta: 10036-2

Vector de Entrada:

Descripción:

El servidor web/aplicación está filtrando información de versión a través de la cabecera de respuesta HTTP "Server". El acceso a dicha información puede facilitar a los atacantes la identificación de otras vulnerabilidades a las que está sujeto su servidor web/aplicación.

Otra información:

Solución:

Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. está configurado para suprimir la cabecera "Server" o proporcionar detalles genéricos.

Referencias:

<https://httpd.apache.org/docs/current/mod/core.html#servertokens>
[https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552\(v=pandp.10\)](https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10))
<https://www.exploit-db.com/exploits/40444/>

Ilustración 2.7 - Alerta información divulgada a través del campo Server

3.7.1 Descripción

El encabezado "Server" puede exponer la versión del servidor web, lo que facilita a los atacantes encontrar fallos conocidos en esa versión específica. La eliminación o modificación de este encabezado reduce el riesgo de ataques dirigidos a vulnerabilidades específicas de la versión del servidor.

3.7.2 Riesgo a futuro

No presenta un fallo crítico, sin embargo, sí representa un gran riesgo a futuro.

Aunque la versión actual esté parcheada, si en un futuro se encuentran vulnerabilidades y no se actualiza, la presencia de este encabezado facilita la búsqueda de exploits para la versión pudiendo afectar la integridad de la web.

Asimismo, en el propio encabezado también muestra información sobre el entorno del servidor (Debian, en este caso). Esto ayuda a los atacantes a hacer ataques más dirigidos y peligrosos.

3.7.3 Probabilidad de que ocurra dicho riesgo

La probabilidad de ocurrencia es media, dado que:

- El encabezado "Server" suele estar habilitado por defecto
- Si se oculta, se puede seguir obteniendo con herramientas de escaneo, así como nmap o curl. Sin autenticación o acceso especial.
- Sin embargo, la explotación es limitada. Únicamente facilita el reconocimiento de posibles vulnerabilidades. Por lo tanto, la posibilidad de que un ataque sea exitoso depende de la seguridad de la web.
- Si se realizan parches de actualización constantes, se reducen drásticamente los riesgos.

3.7.4 Conclusión

La exposición de la versión a través del encabezado "Server" presenta una vulnerabilidad informativa, pudiendo facilitar ataques más dirigidos o la búsqueda de exploits para la versión utilizada. Aunque dicha información se puede ocultar, hay herramientas que la pueden seguir obteniendo sin requisitos de autoridad. No obstante, es recomendable eliminar o deshabilitar este encabezado para mayor seguridad.

Sin embargo, el mejor método para contrarrestar el riesgo es mantener constantes actualizaciones de seguridad.

3.8 Falta encabezado X-Content-Type-Options

Falta encabezado X-Content-Type-Options	
URL:	http://localhost:81/img/insta.png
Riesgo:	Low
Confianza:	Medium
Parámetro:	x-content-type-options
Ataque:	
Evidencia:	
CWE ID:	693
WASC ID:	15
Origen:	Pasivo (10021 - Falta encabezado X-Content-Type-Options)
Vector de Entrada:	
Descripción:	La cabecera Anti-MIME-Sniffing X-Content-Type-Options no se ha establecido en 'nosniff'. Esto permite que las versiones anteriores de Internet Explorer y Chrome realicen MIME-sniffing en el cuerpo de la respuesta, lo que puede provocar que el cuerpo de la respuesta se interprete y se muestre como un tipo de contenido distinto del tipo de contenido declarado. Las versiones actuales (principios de 2014) y heredadas de Firefox utilizarán el tipo de contenido declarado (si se establece uno), en lugar de realizar MIME-sniffing.
Otra información:	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
Solución:	Asegúrese de que la aplicación/servidor web establece el encabezado Content-Type adecuadamente, y que establece el encabezado X-Content-Type-Options a 'nosniff' para todas las páginas web. Si es posible, asegúrese de que el usuario final utiliza un navegador web moderno y compatible con los estándares que no realiza MIME-sniffing en absoluto, o que puede ser dirigido por la aplicación web/servidor web para que no realice MIME-sniffing.
Referencias:	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers

Ilustración 2.8 - Alerta Falta encabezado X-Content-Type-Options

3.8.1 Descripción

El encabezado X-Content-Type-Options previene que los navegadores intenten adivinar el tipo de archivo de una respuesta, lo que podría llevar a la ejecución de contenido malicioso. Su ausencia puede permitir que los atacantes inyecten código malicioso a través de contenido mal interpretado por el navegador.

3.8.2 Riesgo a futuro

No suele ser un riesgo inmediato, pero sí es un riesgo a mediano o largo plazo si no se corrige de manera correcta. Esto puede acarrear diferentes problemas como la ejecución de scripts maliciosos, el riesgo de descarga e interpretación incorrecta de archivos o incluso la posibilidad de exposición de datos o manipulación de contenido si el atacante logra subir archivos al servidor.

3.8.3 Probabilidad de que ocurra dicho riesgo

La probabilidad de que ocurra es media, debido a que:

- Si el sitio web permite subir archivos o mostrar contenido generado por usuarios puede conllevar un riesgo grande.
- Aunque, el riesgo baja si ya existen otras capas de validación de tipo MIME y cabeceras de seguridad complementarias, como por ejemplo, Content-Security-Policy o X-Frame-Options.

3.8.4 Conclusión

Para evitar que el navegador realice interpretaciones incorrectas del contenido, se debe configurar el encabezado de seguridad. Es recomendable su uso ya que es una medida de seguridad esencial y de bajo costo, recomendada todos los estándares modernos de desarrollo web

Este encabezado instruye al navegador a no intentar adivinar el tipo de contenido y a ceñirse estrictamente al tipo MIME declarado por el servidor.

3.9 Divulgación de información - Comentarios sospechosos

Divulgación de información - Comentarios sospechosos	
URL:	http://localhost:81/js/regex.js
Riesgo:	Informational
Confianza:	Low
Parámetro:	
Ataque:	
Evidencia:	Todo
CWE ID:	615
WASC ID:	13
Origen:	Pasivo (10027 - Divulgación de información - Comentarios sospechosos)
Vector de Entrada:	
Descripción:	The response appears to contain suspicious comments which may help an attacker.
Otra información:	The following pattern was used: \bTODO\b and was detected in likely comment: "// ===== Todo esto para verificar o validar los campos =====", see evidence field for the suspicious comment/snippet.
Solución:	Eliminar todos los comentarios que muestren información que pueda ayudar a un atacante y solucionar el problema al que se refieren.
Referencias:	

Ilustración 2.9 - Alerta Comentarios sospechosos

3.9.1 Descripción

Los comentarios en el código fuente pueden contener información sensible que, si no se eliminan antes de la publicación, pueden ser aprovechados por los atacantes. Detalles como configuraciones internas o credenciales pueden filtrarse a través de estos comentarios y poner en riesgo la seguridad del sistema.

3.9.2 Riesgo a futuro

El que se proporcione información del funcionamiento del código y funcionamiento interno de la web facilita la realización de ingeniería inversa para encontrar vulnerabilidades. Además, se corre el riesgo de mostrar la versión de diferentes paquetes que usa la web, pudiendo mostrar una versión con una vulnerabilidad conocida. El mostrar rutas y directorios en los comentarios también hace que los posibles atacantes puedan hacer ataques más dirigidos, o filtrar contenido aún no abierto al público.

3.9.3 Probabilidad de que ocurra dicho riesgo

La probabilidad de que esto sea un problema no es alta, ya que:

- La información proporcionada en los comentarios no era información sensible (usuarios/contraseñas de administradores, claves, etc.).
- Los comentarios que explicaban el funcionamiento del código no daban información que no se pudiese deducir leyendo el propio código (por ejemplo una expresión regular seguido de un comentario mencionando los usos de dicha expresión).
- Los únicos comentarios que podrían presentar un riesgo son comentarios con diferentes *TODO*s, ya que muestran funcionalidades, quizás de seguridad, no implementadas; aunque esta información sería deducible simplemente leyendo el código.

3.9.4 Conclusión

Un error común, que en la gran mayoría de casos no presenta una vulnerabilidad grave, causado por la divulgación de información en comentarios dentro del código. A pesar de que la información presentada no es nada oculto, no es recomendable mostrarla ya que solo facilita el trabajo de los atacantes, aumentando el riesgo de recibir ciberataques.

3.10 Respuesta de Gestión de Sesión Identificada

Respuesta de Gestión de Sesión Identificada	
URL:	http://localhost:81/
Riesgo:	Informational
Confianza:	Medium
Parámetro:	PHPSESSID
Ataque:	
Evidencia:	PHPSESSID
CWE ID:	
WASC ID:	
Origen:	Pasivo (10112 - Respuesta de Gestión de Sesión Identificada)
Vector de Entrada:	
Descripción:	Se ha identificado que la respuesta dada contiene un token de gestión de sesión. El campo 'Other Info' contiene un conjunto de tokens de cabecera que pueden utilizarse en el método Header Based Session Management (gestión de sesión basado en cabecera). Si la petición se encuentra en un contexto que tiene un método Session Management establecido en 'Auto-Detect', esta regla cambiará la gestión de sesión para utilizar los tokens identificados.
Otra información:	cookie:PHPSESSID
Solución:	Se trata de una alerta informativa y no de una vulnerabilidad, por lo que no hay nada que corregir.
Referencias:	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/

Ilustración 2.10 - Alerta Respuesta de Gestión de Sesión Identificada

3.10.1 Descripción

La gestión inadecuada de las sesiones de usuario, como la falta de expiración de sesión o la no invalidación al cerrar sesión, puede permitir que los atacantes secuestren sesiones activas. Un manejo adecuado de las sesiones es esencial para evitar que usuarios no autorizados accedan a información sensible.

3.10.2 Riesgo a futuro

Si la página de Allianz Labubu no implementa un sistema de gestión de sesiones más robusto, sin mecanismos de expiración como renovación o invalidación segura al cerrar sesión, podría permitir la reutilización de tokens de sesión por parte del atacante.

Esto podría suponer un riesgo importante en escenarios donde un usuario acceda a la web desde un equipo público (por ejemplo, un ordenador de la universidad), y la sesión no se haya cerrado, aún habiéndolo cerrado el navegador web.

A futuro, y si no se han tomado medidas al respecto, este fallo podría derivar en accesos no autorizados, robo de datos personales, o suplantación de identidad.

3.10.3 Probabilidad de que ocurra dicho riesgo

La probabilidad de que esto ocurra es media, ya que:

- Dada la presencia de tokens de sesión en cabeceras, y el no uso de un sistema de gestión de sesiones robusto en el sistema web actual, existe una probabilidad considerable de que esta vulnerabilidad sea explotada por atacantes maliciosos, especialmente si no se usa el protocolo HTTPS o si el usuario se olvida de cerrar la sesión.
- Aunque realizar ataques explotando esta vulnerabilidad requiere cierto conocimiento técnico, el ataque se vuelve más factible en presencia de otras vulnerabilidades complementarias, como el CSRF o XSS.

3.10 Conclusión

Una mala gestión de las sesiones puede derivar en vulnerabilidades importantes del sistema web, y es muy recomendable tomar medidas que mejoren la seguridad en este aspecto para evitar situaciones como el secuestro de sesiones activas y el acceso no autorizado a información privada.

Se recomienda la implementación de un sistema que se encargue de gestionar las sesiones de manera segura, por ejemplo mediante mecanismos como la expiración de sesión, configurar las cookies (HttpOnly, Secure, SameSite) adecuadamente y el uso de HTTPS.

3.11 Ataques a fuerza bruta inicio de sesión

3.11.1 Descripción

Los ataques de fuerza bruta consisten en acceder u obtener un objetivo insistiendo. En este caso nos centraremos en el inicio de sesión. Es decir, identificarse en una web empleando una serie de combinaciones frecuentes de usuarios y contraseñas.

3.11.2 Riesgo a futuro

Es uno de los ataques más comunes. El riesgo viene del grado de complejidad usado en los datos de inicio de sesión de los administradores, por ejemplo un usuario con nombre y contraseña 'admin' es más fácil de sacar a fuerza bruta que usuario 'Adm1n_B453+\$&' y contraseña 'd8c12cca7dcba434d5d22f380bafcc20'.

3.11.3 Probabilidad de que ocurra dicho riesgo

La probabilidad de que esto ocurra es media, ya que:

- En nuestra web no limitamos los intentos de inicio de sesión ni guardamos información de esto; esto causa que seamos vulnerables a estos ataques y que no seamos conscientes de que hemos sido atacados.
- Estos ataques requieren un alto nivel computacional, lo cual conlleva que tome mucho tiempo vulnerar nuestros sistemas.

3.11.4 Conclusión

Es un ataque frecuente que presenta un enorme riesgo. No obstante, la probabilidad de que se dé viene de la complejidad que le asigna el usuario propietario de la cuenta a su contraseña. Afortunadamente, son ataques que requieren de mucho tiempo y un gran coste operativo.

Bibliografía

- Arsys. (s.f.). Content Security Policy (CSP). Recuperado de <https://www.arsys.es/blog/csp-content-security-policy>
- BeagleSecurity. (2021). Cookie Session Without HttpOnly Flag. Recuperado de <https://beaglesecurity.com/blog/vulnerability/cookie-session-without-http-only-flag.html>
- Fortinet. (s.f.). Clickjacking. Recuperado de <https://www.fortinet.com/lat/resources/cyberglossary/clickjacking>
- Hackmetrix. (2020). CSRF (Cross-Site Request Forgery). Recuperado de <https://blog.hackmetrix.com/csrf-cross-site-request-forgery/>
- IMMUNE. (2023). Fingerprinting: qué es y herramientas para realizarlo. Recuperado de <https://immune.institute/blog/que-es-fingerprinting-para-que-se-utiliza/>
- INCIBE. (s.f.). Suplantación de identidad. Recuperado de <https://www.incibe.es/ciudadania/tematicas/virus-amenazas/suplantacion-de-identidad>
- Web.dev. (2019). Explicación de las cookies de SameSite. Recuperado de <https://web.dev/articles/samesite-cookies-explained?hl=es>
- NIVEL4. (2024). Ausencia de Cabeceras de Seguridad ¿Cómo afectan a la protección de servicios web y móviles? Recuperado de <https://blog.nivel4.com/noticias/ausencia-de-cabeceras-de-seguridad-como-afectan-a-la-proteccion-de-servicios-web-y-moviles>
- Information Security Stack Exchange. (2012). What is the HTTP "Server" response-header field used for? Recuperado de <https://security.stackexchange.com/questions/23256/what-is-the-http-server-response-header-field-used-for>
- Mozilla Developer Network (MDN). (s.f.). Guía sobre cookies HTTP. Recuperado de <https://developer.mozilla.org/es/docs/Web/HTTP/Guides/Cookies>

- OWASP. (s.f.). HTTP Headers Cheat Sheet. Recuperado de <https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>
- OWASP. (s.f.). HttpOnly. Recuperado de <https://owasp.org/www-community/HttpOnly>
- Rinku. (2025). Information disclosure: qué es y cómo funciona. Recuperado de <https://rinku.tech/information-disclosure>
- StackHawk. (s.f.). HttpOnly Cookie Flag. Recuperado de https://docs-stackhawk-com.translate.goog/vulnerabilities/10020/?_x_tr_sl=en&_x_tr_tl=es&_x_tr_hl=es&_x_tr_pto=rq
- Stack Overflow. (2020). What is the difference between SameSite=Lax and SameSite=Strict? Recuperado de <https://stackoverflow.com/questions/59990864/what-is-the-difference-between-samesite-lax-and-samesite-strict>
- Stack Overflow. (s.f.). What does "x-powered by" mean? Recuperado de <https://stackoverflow.com/questions/33580671/what-does-x-powered-by-mean>